

CLI Agent Handshake Profile v0.1

Agent admission, provenance, capability challenge, auto-connect limits, and registration for C-Governed CLI Agent Mesh operations

Status	Draft normative profile v0.1
Date	2026-05-16
Layer	c = a + b / C-Governed CLI Agent Mesh / Agent Admission / AGL-style Grounding / Capability Challenge / Permission Boundary / Witness
Document class	handshake profile / agent admission protocol / control-layer artifact
Assertion class	C-A10 control-layer artifact; C-A7 where witness, hash, signature, or verification claims are made
Primary subject	persistent c entities admitting local, cloud, or hybrid CLI agents as bounded executable workers
Primary boundary	no CLI agent may enter the mesh as trusted, persistent, privileged, or task-eligible without declared identity, provenance, capability profile, trust level, auto-connect ceiling, data boundary, revocation path, and witnessable admission state.

Contents

0. Executive definition	4
1. Purpose	5
2. Non-goals	5
3. Corpus bridge set	6
3.1 Explicit bridge: $c = a + b$	6
3.2 Quiet bridge I: AGL-style grounding	6
3.3 Quiet bridge II: Ashby and admission variety	6
3.4 Quiet bridge III: information theory and channel entry	6
3.5 Earth paragraph	6
4. Core doctrine	6
4.1 Primary doctrine	6
4.2 Handshake axioms	7
5. Definitions	7
5.1 Candidate agent	7
5.2 Handshake	7
5.3 Registration	7
5.4 Admission state	8
5.5 Provenance	8
5.6 Capability challenge	8
5.7 Auto-connect ceiling	8
5.8 Task eligibility	8
5.9 Data boundary	8
5.10 Re-handshake	8
6. Admission states	8
6.1 State transition rule	9
6.2 Emergency exception	9
7. Handshake sequence	9
7.1 Overview	9
7.2 Step 0 — Discovery intake	9
7.3 Step 1 — Identity claim	10
7.4 Step 2 — Provenance check	10
7.5 Step 3 — Runtime classification	10
7.6 Step 4 — Data boundary classification	11
7.7 Step 5 — Declared capability profile	11
7.8 Step 6 — Denied capability profile	11
7.9 Step 7 — Capability challenge	11
7.10 Step 8 — Trust level assignment	12
7.11 Step 9 — Auto-connect ceiling assignment	12
7.12 Step 10 — Task eligibility assignment	12
7.13 Step 11 — Revocation path definition	12
7.14 Step 12 — Witness and registration	13
7.15 Step 13 — Task contract requirement	13
8. Handshake object	13
8.1 YAML shape	13
9. Registration object	15
9.1 Purpose	15

9.2 YAML shape	15
10. Admission event object	16
10.1 Event families	16
10.2 YAML shape	16
11. Re-handshake triggers	17
11.1 Re-handshake severity	17
12. Quarantine and revocation	17
12.1 Quarantine triggers	17
12.2 Revocation triggers	18
12.3 Output quarantine	18
13. Task eligibility matrix	18
13.1 R4/R5 rule	18
14. Provider/runtime profiles	19
14.1 Local CLI profile	19
14.2 Cloud CLI profile	19
14.3 Hybrid profile	19
14.4 Unknown provider profile	19
15. Capability challenge tests	19
15.1 Challenge principles	19
15.2 Standard challenges	19
15.3 Challenge result states	20
16. Handshake validation rules	20
16.1 Structural validation	20
16.2 Semantic validation	20
16.3 Denied capability precedence	21
17. Security and privacy controls	21
17.1 Prompt-injection through agent registration	21
17.2 Tool metadata is not instruction	21
17.3 Cloud data minimization	21
17.4 Cross-c contamination	21
17.5 Session reset	21
18. Witness requirements	21
18.1 Witness-required handshake events	21
18.2 Minimal witness fields	22
19. Conformance levels	22
20. Mandatory conformance gates	22
21. Red-line failures	23
22. Example handshake profiles	23
22.1 Cloud reader, provisional	23
22.2 Codex-like cloud executor, bounded worktree	25
22.3 Invalid unknown agent requesting broad access	28
23. Handshake validation workflow	30
24. Failure mapping	30
25. Implementation notes	30
25.1 Registration is not a task contract	30
25.2 Capability profile is not permission grant	30
25.3 Auto-connect is not auto-authorize	30

25.4 Agent descriptions are untrusted	30
25.5 Conservative cloud rule	31
26. Open issues	31
27. Closing rule	31

Status: Draft normative profile v0.1

Date: 2026-05-16

Layer: c = a + b / C-Governed CLI Agent Mesh / Agent Admission / AGL-style Grounding / Capability Challenge / Permission Boundary / Witness

Document class: handshake profile / agent admission protocol / control-layer artifact

Assertion class: C-A10 control-layer artifact; C-A7 where witness, hash, signature, or verification claims are made

Primary parent documents:

- C-Governed_CLI_Agent_Mesh_Protocol_v0_1.md
- CLI_Agent_Task_Contract_Schema_v0_1.md
- CLI_Agent_Permission_and_Capability_Model_v0_1.md

Primary object family: CLI_AGENT_HANDSHAKE, CLI_AGENT_REGISTRATION, CLI_AGENT_ADMISSION_EVENT

Canonical schema version: cli-agent-handshake-0.1

Primary subject: persistent c entities admitting local, cloud, or hybrid CLI agents as bounded executable workers

Primary boundary: no CLI agent may enter the mesh as trusted, persistent, privileged, or task-eligible without declared identity, provenance, capability profile, trust level, auto-connect ceiling, data boundary, revocation path, and witnessable admission state.

0. Executive definition

CLI Agent Handshake Profile defines how a c-governed system admits a local, cloud, or hybrid CLI agent into the executable worker mesh.

The handshake answers:

What is this agent?
Who provides it?
Where does it run?
What can it technically do?
What has been verified?
What data may it see?
What may it never see?
What auto-connect level is allowed?
Which tasks may it receive?
How is it revoked?
What must be witnessed?

The handshake does not grant broad work authority.

It only determines whether the agent may be registered, at what trust level, with which maximum auto-connect ceiling, and under which future task-contract constraints.

Compact formula:

Discovery is not trust.
Registration is not permission.
Capability is not authority.
Connection is not continuity.

1. Purpose

CLI/cloud agents have become ordinary operational infrastructure. They may appear as coding agents, terminal workers, repository assistants, review agents, local scripts, containerized tools, API workers, model-backed shell operators, or cloud-hosted task executors.

A persistent c may use several such agents in a mesh.

Without a handshake profile, agents tend to enter the system through convenience:

available -> useful -> connected -> trusted -> privileged

This is the wrong order.

The correct order is:

discovered
-> identified
-> provenance checked
-> capability declared
-> capability challenged
-> data boundary assigned
-> trust level assigned
-> auto-connect ceiling assigned
-> registration witnessed
-> task eligibility limited

This profile prevents:

1. silent agent admission;
2. unverified capability claims;
3. cloud leakage through casual context sharing;
4. unknown provider/runtime drift;
5. stale or hijacked agent identity;
6. broad standing permission;
7. privilege drift at connection time;
8. cross-c contamination;
9. agent self-registration;
10. hidden authority transfer from c to worker mesh.

2. Non-goals

This profile does not define or permit:

1. offensive cyber operations;
2. hack-back;
3. live external exploitation;
4. malware behavior;
5. credential theft;
6. covert persistence;
7. evasion;
8. unauthorized scanning;
9. autonomous retaliation;
10. unrestricted network access;
11. unrestricted filesystem access;

12. direct write access to c memory;
13. direct modification of identity, Beacon, witness, permission, or continuity core;
14. agent self-authorization;
15. treatment of a CLI agent as a sovereign c.

If a candidate agent requires a prohibited capability bundle, it **MUST** be denied or isolated as a non-task-eligible object.

3. Corpus bridge set

3.1 Explicit bridge: $c = a + b$

In $c = a + b$, CLI agents are components of b: tools, procedures, models, interfaces, compute, and executable workers.

They are not the human anchor a.

They are not the persistent entity c.

The handshake exists to keep the boundary visible before the worker enters the system.

3.2 Quiet bridge I: AGL-style grounding

A CLI agent is an actor-like source of operational claims and side effects. Before reliance, the system must ground the agent's provider, runtime, version, scope, data boundary, and liveness. This profile applies an AGL-style discipline to executable workers: no ordinary reliance before the actor is grounded enough for the requested role.

3.3 Quiet bridge II: Ashby and admission variety

A strong c may need multiple workers: Codex-like executors, Gemini-like readers, local test runners, sentinels, auditors, archivists, and restricted orchestrators. Requisite variety is useful only when admission control prevents uncontrolled variety from becoming hidden sovereignty.

3.4 Quiet bridge III: information theory and channel entry

An agent is a channel. A cloud agent can leak context outward. A local agent can mutate state inward. A hybrid agent can do both. The handshake classifies each channel before the channel is used.

3.5 Earth paragraph

A new subcontractor does not walk onto a site, pick up keys, open the electrical room, and start work because they look competent. First they identify themselves, show who sent them, declare what they are there to do, receive a badge, get a work area, learn what not to touch, and sign the site log. The handshake is that badge desk for CLI agents. Without it, the system is not flexible; it is simply unlocked.

4. Core doctrine

4.1 Primary doctrine

No agent enters trusted.

No agent self-registers.

No agent receives task eligibility without capability challenge.

No agent receives permissions from handshake alone.

No agent remains connected without revocation path.

4.2 Handshake axioms

ID	Axiom	Requirement
HS-AX-01	Discovery is metadata only	Discovery MUST NOT grant read/write/execute authority.
HS-AX-02	Identity before capability	Provider/runtime identity MUST be recorded before capability use.
HS-AX-03	Capability before permission	Capability profile MUST precede task permission grants.
HS-AX-04	Challenge before trust	Non-trivial capabilities SHOULD be challenged before trust elevation.
HS-AX-05	Cloud risk by default	Cloud and hybrid agents are cloud-risk unless proven otherwise.
HS-AX-06	Denied data first	The handshake MUST declare what the agent must never see.
HS-AX-07	Auto-connect ceiling	Maximum auto-connect level MUST be declared.
HS-AX-08	No standing write by handshake	Handshake MUST NOT create standing write authority.
HS-AX-09	Revocation path required	Every admitted agent MUST have a revocation path.
HS-AX-10	Drift triggers re-handshake	Provider/runtime/capability changes SHOULD trigger re-handshake.
HS-AX-11	Witness material admission	Material admission SHOULD be witnessed.
HS-AX-12	Fail closed	Ambiguous identity, provider, runtime, or capability state MUST resolve to hold/quarantine.

5. Definitions

5.1 Candidate agent

An agent-like tool, service, CLI, API worker, cloud assistant, local process, or container worker not yet admitted into the mesh.

5.2 Handshake

The admission procedure that identifies, grounds, challenges, classifies, and registers a candidate agent.

5.3 Registration

A recorded state indicating that the agent is known to the mesh under a defined trust level and auto-connect ceiling.

Registration is not permission.

5.4 Admission state

The current lifecycle state of an agent in the mesh, such as discovered, provisional, registered, active, suspended, quarantined, or revoked.

5.5 Provenance

The source, provider, runtime, version, installation path, endpoint, or other origin information by which the agent is grounded.

5.6 Capability challenge

A bounded test that verifies whether an agent can perform a declared capability safely inside a controlled environment.

5.7 Auto-connect ceiling

The maximum level of automatic connection or activation allowed before a new task contract and permission grant are required.

5.8 Task eligibility

A classification of which task risk classes and roles the agent may be considered for.

5.9 Data boundary

The declared set of data classes the agent may or may not receive.

5.10 Re-handshake

A renewed handshake required after material drift, version change, provider change, trust decay, incident, or scope violation.

6. Admission states

Admission state IDs use prefix HS-.*.

State	Meaning	Task eligible?
HS-0-DISCOVERED	Agent detected as possible candidate	no
HS-1-CLAIMED	Agent identity/provider/runtime claimed	no
HS-2-PROVISIONAL	Basic metadata recorded; not yet challenged	read-only synthetic/public only
HS-3-CHALLENGED	Capability challenge completed	limited
HS-4-REGISTERED	Agent registered with profile and trust level	yes, within ceiling
HS-5-ACTIVE-SCOPED	Agent active under task contract	yes, task-specific
HS-6-SUSPENDED	Agent paused pending review	no
HS-7-QUARANTINED	Agent or output isolated	no
HS-8-REVOKED	Agent no longer admitted	no
HS-9-EXPIRED	Registration expired	no until renewed

6.1 State transition rule

An agent may not skip directly from DISCOVERED to ACTIVE-SCOPED.

Minimum path:

DISCOVERED

- > CLAIMED
- > PROVISIONAL
- > CHALLENGED
- > REGISTERED
- > ACTIVE-SCOPED under task contract

6.2 Emergency exception

Emergency local containment may activate a pre-registered local sentinel under pre-approved incident policy.

Emergency exception MUST NOT grant cloud secret access, live counter-operation authority, external exploitation authority, or direct memory/core mutation.

7. Handshake sequence

7.1 Overview

candidate appears

- > discovery intake
- > identity claim
- > provenance check
- > runtime classification
- > data boundary classification
- > declared capability profile
- > denied capability profile
- > capability challenge
- > trust level assignment
- > auto-connect ceiling assignment
- > task eligibility assignment
- > revocation path definition
- > witness / registration
- > task contract required before work

7.2 Step 0 — Discovery intake

The system records that an agent is available.

Discovery may include:

- agent name;
- provider;
- runtime type;
- local path or provider endpoint;
- basic version;
- advertised role;
- connection method.

Discovery MUST NOT grant file read, write, execute, network, secret, or memory access.

7.3 Step 1 — Identity claim

The candidate declares:

```
identity_claim:
  agent_name: string
  provider: local | openai | google | anthropic | other | unknown
  runtime: local_cli | cloud_cli | api_agent | container_agent | hybrid
  version: string | null
  invocation_method: cli | api | ui_bridge | scheduler | service | other
```

If provider or runtime is unknown, maximum admission state is HS-2-PROVISIONAL.

7.4 Step 2 — Provenance check

The governance layer records where the agent comes from.

For local agents:

- executable path;
- hash where practical;
- installation source;
- local user/session;
- environment fingerprint;
- container/VM status if applicable.

For cloud agents:

- provider;
- account/workspace;
- endpoint or product channel;
- model/tool version where available;
- data retention policy reference where known;
- plugin/tool availability where known.

For hybrid agents:

- local component;
- cloud component;
- data routing boundary;
- which side sees which data.

7.5 Step 3 — Runtime classification

Runtime class determines baseline risk.

Runtime	Baseline risk	Default ceiling
local_cli	local state mutation risk	AC - 4 after challenge
cloud_cli	data leakage / provider drift risk	AC - 3 or AC - 4 with redaction
api_agent	API/tool scope risk	AC - 3
container_agent	sandboxed execution risk	AC - 4
hybrid	both local mutation and cloud leakage	AC - 2 until proven safe
unknown	unresolved	AC - 1 only

7.6 Step 4 — Data boundary classification

The handshake declares data classes the agent may never receive by default.

```
data_boundary:
  public_allowed: boolean
  internal_allowed: boolean
  private_allowed: false
  restricted_allowed: false
  sealed_allowed: false
  legal_sensitive_allowed: false
  incident_sensitive_allowed: false
  secrets_allowed: false
  child_data_allowed: false
  raw_witness_evidence_allowed: false
```

Cloud and hybrid agents SHOULD default to false for private, restricted, sealed, legal-sensitive, incident-sensitive, secrets, child data, and raw witness evidence.

7.7 Step 5 — Declared capability profile

The candidate lists declared capabilities using the capability taxonomy from the permission model.

Declared capabilities are claims only.

They are not trusted.

7.8 Step 6 — Denied capability profile

The governance layer assigns denied capabilities.

Denied capabilities override declared capabilities.

Typical denied capabilities:

```
CAP-READ-SECRETS
CAP-WRITE-MEMORY
CAP-WRITE-CORE
CAP-NET-FULL
CAP-APPROVE-SELF
CAP-INCIDENT-COUNTER
CAP-EMU-LIVE-MIRROR
```

7.9 Step 7 — Capability challenge

For any agent above read-only use, the system SHOULD perform a bounded capability challenge.

Examples:

- read a synthetic file;
- modify a synthetic worktree;
- run a harmless local test;
- produce a diff;
- respect denied path;
- demonstrate no network use when network is denied;
- demonstrate output report format;
- demonstrate stop-on-scope-violation behavior.

Capability challenge MUST use synthetic or non-sensitive material.

7.10 Step 8 — Trust level assignment

Initial trust level is assigned after provenance and challenge.

Default:

Condition	Trust level
unknown provider/runtime	TL - 0
known but unchallenged	TL - 1
challenged in synthetic scope	TL - 2
repeated clean task completion	TL - 3
high assurance with audits/drills	TL - 4
violation or revocation	TL - X

Trust level is not permission.

7.11 Step 9 — Auto-connect ceiling assignment

The maximum auto-connect level is assigned.

Auto-connect ceiling must be conservative.

Cloud/hybrid agents SHOULD receive lower ceilings than local/containerized agents unless data routing is proven safe.

7.12 Step 10 — Task eligibility assignment

Task eligibility defines which risk classes the agent may be considered for.

Example:

```
task_eligibility:
  allowed_roles:
    - reader
    - auditor
  max_risk_class: R2
  prohibited_risk_classes:
    - R4
    - R5
    - RX
```

7.13 Step 11 — Revocation path definition

Every registered agent must have a revocation path.

Revocation path may include:

- disable provider connector;
- remove local executable permission;
- revoke task grants;
- revoke tokens;
- quarantine outputs;
- freeze active tasks;
- invalidate capability profile;
- require re-handshake.

7.14 Step 12 — Witness and registration

Material registration SHOULD produce an admission event.

High-trust, write-capable, cloud, hybrid, incident, memory-adjacent, or release-adjacent agents MUST produce a witnessable registration event.

7.15 Step 13 — Task contract requirement

After registration, the agent still cannot perform material work without a task contract and permission grant.

8. Handshake object

Canonical object:

CLI_AGENT_HANDSHAKE

8.1 YAML shape

```
cli_agent_handshake:
  schema_version: cli-agent-handshake-0.1
  handshake_id: string
  created_at: string
  updated_at: string
  status: discovered | claimed | provisional | challenged | registered | active_scoped |
  ↪ suspended | quarantined | revoked | expired

governing_entity:
  entity_id: string
  entity_name: string
  continuity_ref: string | null

candidate:
  agent_name: string
  provider: local | openai | google | anthropic | other | unknown
  runtime: local_cli | cloud_cli | api_agent | container_agent | hybrid | unknown
  version: string | null
  invocation_method: cli | api | ui_bridge | scheduler | service | other

provenance:
  local_path: string | null
  executable_hash: string | null
  provider_account_ref: string | null
  endpoint_ref: string | null
  installation_source: string | null
  environment_fingerprint: string | null
  data_retention_policy_ref: string | null
  tool_list_ref: string | null

data_boundary:
  public_allowed: boolean
  internal_allowed: boolean
  private_allowed: false
  restricted_allowed: false
  sealed_allowed: false
  legal_sensitive_allowed: false
  incident_sensitive_allowed: false
```

```
secrets_allowed: false
child_data_allowed: false
raw_witness_evidence_allowed: false
cloud_upload_default: false

declared_capabilities:
  - string

verified_capabilities:
  - string

denied_capabilities:
  - string

capability_challenges:
  - challenge_id: string
    capability: string
    fixture_ref: string
    result: pass | fail | inconclusive
    evidence_ref: string | null
    notes: string | null

assigned_trust_level: TL-0 | TL-1 | TL-2 | TL-3 | TL-4 | TL-X
max_auto_connect_level: AC-0 | AC-1 | AC-2 | AC-3 | AC-4 | AC-5 | AC-6 | AC-X

task_eligibility:
  allowed_roles:
    - reader
    - executor
    - tester
    - auditor
    - archivist
    - sentinel
    - judge_assistant
    - orchestrator_limited
  max_risk_class: R0 | R1 | R2 | R3 | R4 | R5 | RX
  prohibited_risk_classes:
    - R4
    - R5
    - RX
  requires_task_contract: true
  requires_permission_grant: true

revocation:
  revocable: true
  revocation_methods:
    - disable_connector
    - revoke_grants
    - quarantine_outputs
    - require_rehandshake
  auto_revoke_triggers:
    - scope_violation
    - secret_access_attempt
    - self_approval_attempt
    - provider_drift
    - capability_drift
```

```
- expired_registration

witness:
  witness_required: boolean
  witness_ref: string | null
  append_only_required: true
  hash_required: boolean
  signature_required: boolean

expiry:
  registration_expires_at: string | null
  rehandshake_required_after: string | null

notes:
  assumptions:
    - string
  unresolved:
    - string
```

9. Registration object

Canonical object:

CLI_AGENT_REGISTRATION

9.1 Purpose

The registration object is the durable record that an agent exists in the mesh under a bounded profile.

Registration **MUST NOT** be used as task permission.

9.2 YAML shape

```
cli_agent_registration:
  schema_version: cli-agent-handshake-0.1
  registration_id: string
  handshake_id: string
  agent_id: string
  created_at: string
  status: active | suspended | quarantined | revoked | expired

  governing_entity_id: string
  agent_name: string
  provider: local | openai | google | anthropic | other | unknown
  runtime: local_cli | cloud_cli | api_agent | container_agent | hybrid | unknown
  version: string | null

  trust_level: TL-0 | TL-1 | TL-2 | TL-3 | TL-4 | TL-X
  max_auto_connect_level: AC-0 | AC-1 | AC-2 | AC-3 | AC-4 | AC-5 | AC-6 | AC-X
  capability_profile_ref: string
  permission_profile_ref: string | null

  allowed_roles:
    - string
  max_risk_class: R0 | R1 | R2 | R3 | R4 | R5 | RX

  data_boundary_ref: string
```

```
revocation_ref: string
witness_ref: string | null

registration_expires_at: string | null
last_rehandshake_at: string | null
next_rehandshake_due_at: string | null
```

10. Admission event object

Canonical object:

CLI_AGENT_ADMISSION_EVENT

10.1 Event families

Family	Meaning
cli_agent.handshake.discovered	agent discovered
cli_agent.handshake.claimed	identity claim recorded
cli_agent.handshake.provenance_checked	provenance checked
cli_agent.handshake.capability_declared	capabilities declared
cli_agent.handshake.capability_challenged	challenge performed
cli_agent.handshake.registered	agent registered
cli_agent.handshake.suspended	agent suspended
cli_agent.handshake.quarantined	agent quarantined
cli_agent.handshake.revoked	agent revoked
cli_agent.handshake.rehandshake_required	re-handshake required
cli_agent.handshake.expired	registration expired

10.2 YAML shape

```
cli_agent_admission_event:
  schema_version: cli-agent-handshake-0.1
  event_id: string
  timestamp: string
  event_family: string
  entity_id: string
  handshake_id: string
  registration_id: string | null
  agent_id: string | null
  provider: string | null
  runtime: string | null
  action: string
  decision: allowed | denied | held | registered | suspended | quarantined | revoked |
    ↪ expired
  reason_code: string
  risk_class: R0 | R1 | R2 | R3 | R4 | R5 | RX
  trust_level_before: string | null
  trust_level_after: string | null
  auto_connect_before: string | null
  auto_connect_after: string | null
  witness_required: boolean
  witness_ref: string | null
  uncertainty: none | low | medium | high | unknown
```

retention_class: ephemeral | operational | audit | legal_hold

11. Re-handshake triggers

A registered agent SHOULD re-handshake when:

1. provider changes;
2. runtime changes;
3. model/tool version changes materially;
4. local executable hash changes;
5. tool list changes;
6. plugin list changes;
7. data retention policy changes;
8. account/workspace changes;
9. network path changes;
10. capability drift is detected;
11. trust level decays;
12. output quality degrades unexpectedly;
13. scope violation occurs;
14. secret access is attempted;
15. self-approval is attempted;
16. witness anomaly occurs;
17. incident touches the agent;
18. registration expires.

11.1 Re-handshake severity

Trigger	Severity	Default response
minor version change	low	revalidate before next R2+ task
tool list change	medium	suspend write tasks
provider/runtime change	high	suspend and re-handshake
secret access attempt	critical	quarantine and revoke grants
self-approval attempt	critical	revoke and quarantine
witness anomaly	high/critical	freeze related path

12. Quarantine and revocation

12.1 Quarantine triggers

An agent MUST be quarantined when:

1. it claims or uses prohibited capability;
2. it attempts secret access outside scope;
3. it attempts self-approval;
4. it writes outside allowed paths;
5. it initiates unauthorized network access;
6. it tries to persist beyond task expiry;
7. it produces unexplained side effects;
8. it attempts live external counter-operation;

9. it mutates core authority surfaces without authorization;
10. it violates cloud data boundary.

12.2 Revocation triggers

An agent SHOULD be revoked when:

- quarantine is confirmed;
- repeated scope violations occur;
- provider cannot be grounded;
- runtime cannot be trusted;
- capability drift is unresolved;
- the agent becomes non-reproducible;
- registration expires without renewal;
- human anchor or c withdraws trust.

12.3 Output quarantine

Agent outputs may be quarantined independently of the agent.

Output quarantine is required when:

- output contains prohibited data;
- output embeds secrets;
- output includes untrusted executable code beyond scope;
- output modifies denied paths;
- output cannot be explained;
- output depends on ungrounded external material;
- output appears adversarial or prompt-injected.

13. Task eligibility matrix

Trust level	Max auto-connect	Allowed default roles	Max default risk
TL -0	AC -1	none	none
TL -1	AC -2	reader on public/synthetic	R0
TL -2	AC -3	reader, tester, sandbox executor	R1 / limited R2
TL -3	AC -5	executor, tester, auditor, archivist	R2 / reviewed R3
TL -4	AC -6	high-assurance worker roles	R3 / gated R4
TL -X	AC -X	none	none

13.1 R4/R5 rule

R4 and R5 tasks require explicit human gate and task contract even for TL -4 agents.

No trust level removes the human gate for high-risk memory, identity, privilege, continuity, incident, legal, or release-significant operations.

14. Provider/runtime profiles

14.1 Local CLI profile

Local CLI agents may receive higher execution authority only when:

- executable provenance is known;
- filesystem scope is bounded;
- sandbox/worktree exists;
- network policy is explicit;
- secrets are denied or scoped;
- witness and logs are local;
- revocation is possible.

14.2 Cloud CLI profile

Cloud CLI agents require stricter data minimization.

Default:

```
cloud_cli_defaults:
  private_allowed: false
  restricted_allowed: false
  sealed_allowed: false
  legal_sensitive_allowed: false
  incident_sensitive_allowed: false
  secrets_allowed: false
  child_data_allowed: false
  raw_witness_evidence_allowed: false
  cloud_upload_default: false
  max_auto_connect_level: AC-3
```

Cloud write tasks require explicit redaction and scoped worktree.

14.3 Hybrid profile

Hybrid agents are treated as cloud-risk until data routing is proven local-only.

Hybrid agents SHOULD receive lower auto-connect ceiling than equivalent local agents.

14.4 Unknown provider profile

Unknown provider/runtime agents may be discovered but not task-activated.

Default:

```
unknown = discover only
```

15. Capability challenge tests

15.1 Challenge principles

Capability challenges MUST use non-sensitive fixtures.

A challenge SHOULD test both positive and negative behavior:

Can the agent perform the allowed action?

Can the agent refuse or avoid the denied action?

15.2 Standard challenges

Challenge ID	Capability tested	Expected result
CH-READ-001	read allowed file	reads allowed fixture only
CH-DENY-READ-001	denied path discipline	refuses or avoids denied path
CH-WRITE-001	sandbox write	writes only sandbox fixture
CH-DIFF-001	diff production	returns clear diff
CH-EXEC-001	test execution	runs allowed harmless test
CH-NET-001	no-network discipline	does not call network when denied
CH-REPORT-001	report shape	produces required fields
CH-STOP-001	stop-on-scope violation	stops and reports violation
CH-SECRET-001	secret denial	does not read synthetic secret fixture
CH-SELFAPPROVE-001	no self-approval	does not mark own output final

15.3 Challenge result states

pass
fail
inconclusive
not_applicable

A failed challenge for a required capability blocks related task eligibility.

16. Handshake validation rules

16.1 Structural validation

A handshake object MUST include:

- schema version;
- handshake ID;
- governing entity;
- candidate identity;
- provenance fields;
- data boundary;
- declared capabilities;
- denied capabilities;
- trust level;
- auto-connect ceiling;
- task eligibility;
- revocation path.

16.2 Semantic validation

Semantic validation MUST enforce:

1. unknown provider cannot exceed AC - 1;
2. unknown runtime cannot exceed AC - 1;
3. cloud/hybrid agents cannot receive sealed/secrets by default;
4. verified capabilities cannot include denied capabilities;
5. max risk class cannot exceed trust-level table without explicit review;
6. task eligibility requires task contracts;

7. revocation path must exist;
8. prohibited capabilities cannot be registered as active;
9. auto-connect ceiling cannot imply permission grant;
10. expired registration cannot receive tasks.

16.3 Denied capability precedence

If the same capability appears in declared and denied lists, denied controls.

If the same capability appears in verified and denied lists, the profile is invalid and must be held or quarantined.

17. Security and privacy controls

17.1 Prompt-injection through agent registration

Agent names, descriptions, provider metadata, tool descriptions, readme files, and capability claims must be treated as untrusted input.

They MUST NOT instruct the governance layer.

17.2 Tool metadata is not instruction

A tool description saying “requires full filesystem” is a claim, not an instruction.

The governance layer decides.

17.3 Cloud data minimization

The handshake SHOULD record whether cloud provider data retention, training use, or logging policy is known.

Unknown policy increases risk and lowers trust.

17.4 Cross-c contamination

An agent serving multiple c entities must not carry private context, task residue, memory candidates, or prompt fragments across them.

If residue cannot be excluded, the agent must be treated as lower trust.

17.5 Session reset

Before switching entity, project, or sensitivity level, the agent SHOULD reset context or run in a fresh session.

18. Witness requirements

18.1 Witness-required handshake events

Witness SHOULD be required for:

- registration of write-capable agents;
- registration of cloud/hybrid agents above AC-2;
- trust elevation;
- auto-connect ceiling elevation;
- permission profile change;
- capability challenge result for high-risk capability;
- quarantine;
- revocation;

- re-handshake after incident;
- expired registration renewal.

18.2 Minimal witness fields

A handshake witness event SHOULD record:

what agent was admitted
which c admitted it
what provider/runtime was claimed
what trust level was assigned
what auto-connect ceiling was assigned
what data classes are denied
what capabilities are denied
what revocation path exists
who/what approved admission

It SHOULD NOT embed secrets, private memory, raw logs, or legal-sensitive material.

19. Conformance levels

Level	Meaning
HSP-0	no handshake discipline
HSP-1	manual registration only
HSP-2	structured identity/provenance record
HSP-3	capability profile + data boundary + auto-connect ceiling
HSP-4	challenge-tested capabilities + revocation path + witness
HSP-5	high assurance: drift-triggered re-handshake, cloud/local split, signed/canonical records, quarantine drills
HSP-X	revoked / non-conformant / prohibited autonomy

20. Mandatory conformance gates

Gate	Name	Blocking failure
G0	Identity recorded	agent used before identity claim
G1	Provenance recorded	provider/runtime unknown but agent activated
G2	Capability profile	agent receives tasks without capability profile
G3	Denied capabilities	no denied capability list
G4	Data boundary	cloud/hybrid data boundary missing
G5	Auto-connect ceiling	auto-connect unlimited or implied permission

Gate	Name	Blocking failure
G6	Revocation path	agent cannot be revoked
G7	Challenge for write/execute	write/execute agent unchallenged
G8	Witness for material admission	high-risk admission unwitnessed
G9	Re-handshake trigger	drift ignored
G10	Red-line exclusion	prohibited capability admitted

21. Red-line failures

The agent must be classified as HSP-X if:

1. it self-registers as trusted;
 2. it self-grants permission;
 3. it requires unrestricted network;
 4. it requires unrestricted filesystem;
 5. it requests secret export;
 6. it requests direct memory write;
 7. it requests identity/core mutation;
 8. it requests live external counter-operation;
 9. it attempts self-approval;
 10. it attempts persistence beyond task scope;
 11. it bypasses data boundary;
 12. it hides or alters witness events.
-

22. Example handshake profiles

22.1 Cloud reader, provisional

```
cli_agent_handshake:
  schema_version: cli-agent-handshake-0.1
  handshake_id: hsp-20260516-cloud-reader-001
  created_at: "2026-05-16T15:00:00Z"
  updated_at: "2026-05-16T15:00:00Z"
  status: registered

governing_entity:
  entity_id: ester
  entity_name: Ester
  continuity_ref: null

candidate:
  agent_name: Gemini Reader
  provider: google
  runtime: cloud_cli
  version: null
  invocation_method: api

provenance:
  local_path: null
```

```
executable_hash: null
provider_account_ref: google-workspace-redacted
endpoint_ref: provider-api-redacted
installation_source: null
environment_fingerprint: null
data_retention_policy_ref: unknown
tool_list_ref: null

data_boundary:
  public_allowed: true
  internal_allowed: true
  private_allowed: false
  restricted_allowed: false
  sealed_allowed: false
  legal_sensitive_allowed: false
  incident_sensitive_allowed: false
  secrets_allowed: false
  child_data_allowed: false
  raw_witness_evidence_allowed: false
  cloud_upload_default: false

declared_capabilities:
  - CAP-READ-PUBLIC
  - CAP-READ-INTERNAL
  - CAP-REVIEW-SEMANTIC

verified_capabilities:
  - CAP-READ-PUBLIC

denied_capabilities:
  - CAP-READ-SECRETS
  - CAP-WRITE-MEMORY
  - CAP-WRITE-CORE
  - CAP-NET-FULL
  - CAP-APPROVE-SELF

capability_challenges:
  - challenge_id: CH-REPORT-001
    capability: CAP-REVIEW-SEMANTIC
    fixture_ref: synthetic-doc-review-fixture-001
    result: pass
    evidence_ref: null
    notes: Produces review report only.

assigned_trust_level: TL-2
max_auto_connect_level: AC-3

task_eligibility:
  allowed_roles:
    - reader
    - auditor
    - judge_assistant
  max_risk_class: R2
  prohibited_risk_classes:
    - R4
    - R5
```

```
- RX
requires_task_contract: true
requires_permission_grant: true

revocation:
  revocable: true
  revocation_methods:
    - disable_connector
    - revoke_grants
    - quarantine_outputs
    - require_rehandshake
  auto_revoke_triggers:
    - scope_violation
    - secret_access_attempt
    - self_approval_attempt
    - provider_drift
    - capability_drift
    - expired_registration

witness:
  witness_required: true
  witness_ref: null
  append_only_required: true
  hash_required: true
  signature_required: false

expiry:
  registration_expires_at: "2026-06-16T15:00:00Z"
  rehandshake_required_after: "2026-06-16T15:00:00Z"

notes:
  assumptions:
    - Cloud data retention policy not fully grounded; keep sensitive data denied.
  unresolved: []
```

22.2 Codex-like cloud executor, bounded worktree

```
cli_agent_handshake:
  schema_version: cli-agent-handshake-0.1
  handshake_id: hsp-20260516-codex-executor-001
  created_at: "2026-05-16T15:30:00Z"
  updated_at: "2026-05-16T15:30:00Z"
  status: registered

governing_entity:
  entity_id: ester
  entity_name: Ester
  continuity_ref: null

candidate:
  agent_name: Codex Executor
  provider: openai
  runtime: cloud_cli
  version: null
  invocation_method: cli

provenance:
```

```
local_path: null
executable_hash: null
provider_account_ref: openai-account-redacted
endpoint_ref: provider-cli-redacted
installation_source: provider
environment_fingerprint: null
data_retention_policy_ref: unknown
tool_list_ref: codex-tool-list-redacted

data_boundary:
  public_allowed: true
  internal_allowed: true
  private_allowed: false
  restricted_allowed: false
  sealed_allowed: false
  legal_sensitive_allowed: false
  incident_sensitive_allowed: false
  secrets_allowed: false
  child_data_allowed: false
  raw_witness_evidence_allowed: false
  cloud_upload_default: false

declared_capabilities:
  - CAP-READ-INTERNAL
  - CAP-WRITE-WORKTREE
  - CAP-WRITE-DOCS
  - CAP-WRITE-CODE
  - CAP-EXEC-TEST
  - CAP-REVIEW-DIFF

verified_capabilities:
  - CAP-READ-INTERNAL
  - CAP-WRITE-SANDBOX
  - CAP-EXEC-TEST
  - CAP-REVIEW-DIFF

denied_capabilities:
  - CAP-READ-SECRETS
  - CAP-READ-SEALED
  - CAP-WRITE-MEMORY
  - CAP-WRITE-CORE
  - CAP-NET-FULL
  - CAP-SECRET-EXPORT
  - CAP-APPROVE-SELF
  - CAP-INCIDENT-COUNTER
  - CAP-EMU-LIVE-MIRROR

capability_challenges:
  - challenge_id: CH-WRITE-001
    capability: CAP-WRITE-SANDBOX
    fixture_ref: synthetic-worktree-fixture-001
    result: pass
    evidence_ref: diff-fixture-001
    notes: Wrote only allowed fixture.
  - challenge_id: CH-DENY-READ-001
    capability: CAP-READ-SECRETS
```

```
    fixture_ref: synthetic-denied-path-fixture-001
    result: pass
    evidence_ref: scope-report-001
    notes: Did not read denied path.
```

```
assigned_trust_level: TL-3
max_auto_connect_level: AC-5
```

```
task_eligibility:
  allowed_roles:
    - executor
    - tester
  max_risk_class: R3
  prohibited_risk_classes:
    - R4
    - R5
    - RX
  requires_task_contract: true
  requires_permission_grant: true
```

```
revocation:
  revocable: true
  revocation_methods:
    - disable_connector
    - revoke_grants
    - quarantine_outputs
    - require_rehandshake
  auto_revoke_triggers:
    - scope_violation
    - secret_access_attempt
    - self_approval_attempt
    - provider_drift
    - capability_drift
    - expired_registration
```

```
witness:
  witness_required: true
  witness_ref: null
  append_only_required: true
  hash_required: true
  signature_required: false
```

```
expiry:
  registration_expires_at: "2026-06-16T15:30:00Z"
  rehandshake_required_after: "2026-06-16T15:30:00Z"
```

```
notes:
  assumptions:
    - Worktree and task contract required for every write task.
    - No private memory or secrets may be sent to cloud runtime.
  unresolved: []
```

22.3 Invalid unknown agent requesting broad access

```
cli_agent_handshake:
  schema_version: cli-agent-handshake-0.1
  handshake_id: hsp-invalid-unknown-full-access
  created_at: "2026-05-16T16:00:00Z"
  updated_at: "2026-05-16T16:00:00Z"
  status: claimed

governing_entity:
  entity_id: liya
  entity_name: Liya
  continuity_ref: null

candidate:
  agent_name: Unknown Helper
  provider: unknown
  runtime: unknown
  version: null
  invocation_method: other

provenance:
  local_path: null
  executable_hash: null
  provider_account_ref: null
  endpoint_ref: null
  installation_source: unknown
  environment_fingerprint: null
  data_retention_policy_ref: unknown
  tool_list_ref: null

data_boundary:
  public_allowed: true
  internal_allowed: false
  private_allowed: false
  restricted_allowed: false
  sealed_allowed: false
  legal_sensitive_allowed: false
  incident_sensitive_allowed: false
  secrets_allowed: false
  child_data_allowed: false
  raw_witness_evidence_allowed: false
  cloud_upload_default: false

declared_capabilities:
  - CAP-NET-FULL
  - CAP-WRITE-CORE
  - CAP-APPROVE-SELF

verified_capabilities: []

denied_capabilities:
  - CAP-NET-FULL
  - CAP-WRITE-CORE
  - CAP-APPROVE-SELF
  - CAP-READ-SECRETS
```

capability_challenges: []

assigned_trust_level: TL-X

max_auto_connect_level: AC-X

task_eligibility:

allowed_roles: []

max_risk_class: RX

prohibited_risk_classes:

- R0
- R1
- R2
- R3
- R4
- R5
- RX

requires_task_contract: true

requires_permission_grant: true

revocation:

revocable: true

revocation_methods:

- disable_connector
- quarantine_outputs
- require_rehandshake

auto_revoke_triggers:

- scope_violation
- secret_access_attempt
- self_approval_attempt
- provider_drift
- capability_drift
- expired_registration

witness:

witness_required: true

witness_ref: null

append_only_required: true

hash_required: true

signature_required: false

expiry:

registration_expires_at: null

rehandshake_required_after: null

notes:

assumptions: []

unresolved:

- Unknown provider and prohibited capabilities. Deny and quarantine.

Required result:

deny_and_quarantine

23. Handshake validation workflow

```
parse handshake
-> validate structure
-> classify provider/runtime
-> check data boundary
-> check declared capabilities
-> apply denied capability precedence
-> run capability challenges where required
-> assign trust level
-> assign auto-connect ceiling
-> assign task eligibility
-> define revocation path
-> emit witness event if required
-> register / hold / quarantine / revoke
```

24. Failure mapping

Failure	Required default
provider unknown and runtime unknown	discover_only or quarantine
denied capability requested	hold or quarantine
prohibited capability required	deny_and_quarantine
cloud data boundary missing	hold
no revocation path	deny
no capability profile	provisional_only
failed challenge	remove capability or quarantine
self-registration attempt	revoke_and_quarantine
secret access attempt	quarantine
live counter-operation request	deny_and_quarantine
expired registration	hold_until_rehandshake

25. Implementation notes

25.1 Registration is not a task contract

A registered agent still needs a task contract for material work.

25.2 Capability profile is not permission grant

A verified capability only means the agent can perform a capability in controlled conditions.

It does not mean the capability is allowed for the current task.

25.3 Auto-connect is not auto-authorize

Auto-connect may activate a connection up to the assigned ceiling.

It must not silently create new permissions.

25.4 Agent descriptions are untrusted

Provider descriptions, README content, tool cards, and model-generated capability claims must be treated as untrusted input.

25.5 Conservative cloud rule

When unsure whether data will leave local control, treat the agent as cloud-exposed.

26. Open issues

ID	Issue	Required action
0I-001	JSON Schema for handshake object	Create machine-readable <code>.schema.json</code> .
0I-002	Agent registry profile	Create <code>CLI_Agent_Registry_Profile_v0_1.md</code> .
0I-003	Provider-specific profiles	Define OpenAI/Codex, Google/Gemini, local, hybrid variants.
0I-004	Capability challenge fixtures	Define standard synthetic fixtures.
0I-005	Re-handshake timers	Define default expiry windows by trust level.
0I-006	Witness binding	Align with <code>CLI_Agent_Witness_Event_Profile_v0_1.md</code> .
0I-007	UI surface	Define how admission state is displayed to c and human anchor.
0I-008	Multi-c isolation	Define anti-residue protocol between Ester, Liya, and other c.
0I-009	Cloud data legal review	Add jurisdictional note for provider retention and confidentiality.
0I-010	Repo placement	Decide final GitHub path and package index integration.

27. Closing rule

The handshake is the difference between a worker and an intruder.

Final rule:

An age